



Module 12 Day 2: Introduction to Intrusion Detection, Snort, and Network Security Monitoring

Class Instruction

Overview

In the last class, you learned that firewalls play a critical role in establishing a perimeter defense using access controls by allowing or denying traffic from trusted and untrusted networks. You also learned the limitations of firewalls.

Today, you will build on these concepts utilizing an alternative defense-in-depth methodology that involves intrusion detection systems, such as Snort IDS. You will learn how to use Network Security Monitoring (NSM), like Security Onion, and the Snort IDS engine to analyze indicators of attack (IOA), indicators of compromise (IOC), perform network forensics, and acquire intelligence and situational awareness of their networks. This will provide them with the necessary information to defend against network attacks.

Class Objectives

By the end of today's class, students will be able to:

- Interpret and define Snort rules and alerts.
- Explain how intrusion detection systems work and how they differ from firewalls.
- Learn the difference between an intrusion detection system (IDS) and an intrusion prevention system (IPS).
- Use Security Onion and its suite of network security monitoring tools to trace the path of network attacks.
- Collect and analyze indicators of attack (IOA) and indicators of compromise (IOC) using NSM tools.
- Apply knowledge of NSM, Snort rules, and Security Onion to establish situational awareness within a network.

Lab Environment

For today's lesson, you will use the NetSec lab environment. Log in using the following credentials:

- Security Onion VM:
 - Username: **sysadmin**
 - Password: **cybersecurity**

Lesson Slideshow

The lesson slides are available on Google Drive here: [12.2 Slides](#)

01. Security Onion Setup

Today's lesson will introduce fundamental concepts and tools of network security monitoring, intrusion detection, and Snort.

Before we get started, we will need to log into Azure and launch an instance of Security Onion. Then, we will generate alert data that we'll use later in the class. Specifically, a Security Onion VM will spin up and loaded PCAPs will be replayed.

- The following file contains instructions to set up Security Onion for today's lesson and activities.
- As we wait for Security Onion to be completed, recall that you used Wireshark to work with PCAPs in the networking module.
 - PCAPs are snapshots of live traffic.
 - In the networking modules, you loaded PCAPs into Wireshark.
 - In Security Onion, we will use the command `sudo so-test` to replay multiple PCAPS stored in the `/opt/so/samples` directory, which can store hundreds of PCAPs.
 - It's essential that network defenders know how to replay network traffic using PCAPs to analyze and triage alert data.

Use the following file and follow the instructor's lead in performing the setup:

- [Activity File: Security Onion Setup](#)
-

02. Welcome and Overview

Network Security Recap

Let's begin by reviewing the basic concepts:

- Firewalls protect networks by making decisions based on rules that are set by administrators. Firewalls are designed to allow traffic from trusted sources and block traffic from untrusted sources.
- Firewalls do have their limitations. Advanced hackers can easily fool them through packet manipulation.
 - For instance, an attacker can send malicious data through a firewall by hijacking or impersonating a trusted machine. This is why it's crucial to have a strong defense-in-depth methodology to help protect sensitive data.
 - Firewalls are only one layer of defense.

Note the following:

- The first half of the day we'll begin with the introduction to Intrusion Detection & Prevention systems and Snort IDS, how to physically interconnect IDS systems, and how to read, write, and interpret Snort rules.
 - The second half of the day will introduce you to Security Onion and the role NSM tools play in the realm of network security.
-

03. Intro to Intrusion Detection Systems and Snort

Today, we'll explore the world of intrusion detection systems and how they differ from firewalls.

Recall that a firewall is a device used in network security designed to filter ingress (inbound) and egress (outbound) traffic, based on a set of predetermined administratively defined rules.

- Firewalls either allow or block traffic based on the following:
 - Source and destination IP address
 - Source and destination port number
 - Protocol type
- Firewalls have their limitations. They can easily be fooled through packet manipulation by clever hackers.
 - For instance, attackers can send malicious data through a firewall by hijacking or impersonating a trusted machine.
- Unlike firewalls, intrusion prevention and detection systems monitor, detect, and alert about an attack depending upon the configuration.

Intrusion detection systems (IDS) are tools that can both analyze traffic *and* look for malicious signatures. An IDS is like a firewall that also reads the data in the packets it inspects, issues alerts/alarms, and blocks malicious traffic if configured to do so.

- There are many varieties of intrusion detection systems, but today's class will begin by focusing on **Snort**, the world's most popular open-source solution.

Network security monitoring (NSM) is the process of identifying weaknesses within a network's defense. It also provides organizations with situational awareness of their network.

- There are a variety of NSM solutions. **Security Onion** is an NSM that will be covered in more detail later in this module. It uses a specific Linux distribution that's derived from Oracle Linux.

Intrusion Detection System Overview

Intrusion detection systems (IDS) are passive devices that perform packet captures of all traffic that passes through a network interface.

- Intrusion detection systems are not designed to *respond* to an attack, but rather to document and log attacks for future analysis.
- Intrusion detection systems help organizations enforce the cyber kill chain by establishing situational awareness of their adversaries, which may include intent and end objectives. Organizations can use this information to harden their defenses.

IDS Types

There are two primary types of IDS:

- **Signature-based** IDS compares patterns of traffic to predefined signatures. It has the following characteristics:
 - Good for identifying well-known attacks
 - Requires regular updates as new attack signatures are released
 - Vulnerable to attacks through packet manipulation that tricks the IDS into believing malicious traffic is good
 - Unable to detect zero-day attacks
- **Anomaly-based** IDS compares patterns of traffic against a well-known baseline. This type of device typically uses **machine learning**, an area of **artificial intelligence**, to review vast amounts of data to statistically identify potential threats. It has the following characteristics:
 - Good for detecting all suspicious traffic that deviates from the well-known baseline
 - Prone to issuing false alerts or false positives
 - Assumes normal network behavior never deviates from the well-known baseline
 - Excellent at detecting when an attacker probes or sweeps on a network

Intrusion Detection Architecture

Intrusion detection systems have two basic architectures:

- **Network intrusion detection system (NIDS)** examines traffic on an entire subnet on a network.
 - Matches all traffic to a known library of attack signatures
 - Passively examines network traffic at the points it is deployed
 - Relatively easy to deploy and difficult to detect by attackers
- **Host-based intrusion detection system (HIDS)** runs locally on a host-based system or user's workstation or server. It has the following characteristics:
 - Acts as a second line of defense against malicious traffic that successfully bypasses a NIDS
 - Examines entire file systems on a host, compares them to previous snapshots or a baseline, and generates an alert if there are significant differences between the two

Intrusion Prevention System

An **intrusion prevention system (IPS)** does everything that an IDS can do, but can also respond to attacks. An IDS doesn't alter or react to packets as they enter the network. An IPS does this by blocking malicious traffic and preventing it from being delivered to a host on the network.

The two main differences between an IPS and IDS:

1. IDS physically connects via a network tap or mirrored port or SPAN.
 - **Network tap** (Test Access Port) is a hardware device that provides access to a network. Network taps transit both inbound and outbound data streams on separate channels at the same time, so all data will arrive at the monitoring device in real time.
 - **SPAN** (Switched Port Analyzer), also known as **port mirroring**, sends a mirror image of all network data to another physical port, where the packets can be captured and analyzed.
 - IDS requires an administrator to react to an alert by examining what has been flagged.
2. IPS physically connects inline with the flow of data. An IPS is typically placed in between the firewall and network switch.
 - Requires more robust hardware due to the amount of traffic flowing through it
 - Automatically takes action by blocking and logging a threat, thus not requiring administrative intervention

An IDS generates an alert when a Snort rule detects malicious traffic that matches a signature. An alert is a message that's created and sent to the analyst's console as an **indicator of attack (IOA)**.

There are two primary types of indicators:

1. **Indicators of attack (IOA)** indicate attacks happening in real time.
 - It is a proactive approach to intrusion attempts.
 - It indicates that an attack is currently in progress but a full breach has not been determined or has not occurred yet.

- It focuses on revealing the intent and end goal of the attacker regardless of the exploit or malware used in the attack.
- 2. **Indicators of compromise (IOC)** indicate previous malicious activity.
 - It is a reactive approach to successful intrusions
 - It indicates that an attack occurred, resulting in a breach/
 - It is used to establish an adversary's techniques, tactics, and procedures (TTPs)
 - It exposes all the vulnerabilities used in an attack, giving network defenders the opportunity to revamp their defense as part of their mitigation strategy, and learn from an attack so it won't happen again.

Snort

Snort is a freely available open-source network intrusion detection/prevention system. It can perform real-time traffic analysis and log packets on a network. Snort is used to detect a wide variety of attacks.

- Snort adds additional layers of defense that can be applied at various layers of the defense-in-depth model, including:
 - Perimeter IDS and IPS architecture
 - Network IDS and IPS architecture
 - Host IDS and IPS architecture
- Configuration Modes
Snort can operate in three modes:
 - **Sniffer Mode:** Reads network packets and displays them on screen
 - **Packet Logger Mode:** Performs packet captures by logging all traffic to disk
 - **Network Intrusion Detection System Mode:** Monitors network traffic, analyzes it, and performs specific actions based on administratively defined rules

Most Snort deployments use all three modes of operation.

Snort Rules

Snort uses rules to detect and prevent intrusions. Snort operates by:

1. Reading a configuration file
2. Loading the rules and plugins
3. Capturing packets and monitoring traffic for patterns specified in the loaded rules
4. When traffic matches a rule pattern, generating an alert and/or logging the matching packet for later inspection

Rules can direct Snort to monitor the following information:

- OSI layer: Watches for IP vs. TCP data
- Source and destination address: To and from where the traffic is flowing
- Byte sequences: Patterns contained in data packets that might indicate malware, etc.

Consider the following Snort rule:

- `alert ip any any -> any any {msg: "IP Packet Detected";}`
- This rule logs the message "IP Packet Detected" whenever it detects an IP packet.

Another example:

```
alert tcp any 21 -> 10.199.12.8 any {msg: "TCP Packet Detected";}
```

- This rule triggers an alert whenever a TCP packet from port 21, with any source IP address, is sent to the IP 10.199.12.8. With each alert, it will print the message "TCP Packet Detected."
- Rule Header
 - `alert` is the action that Snort will take when triggered.
 - `tcp` applies the rule to all TCP packets.
 - `any` applies the rule to packets coming from any source IP address.
 - `21` applies the rule to packets from port 21.
 - `->` indicates the direction of traffic.
 - `10.199.12.8` applies the rule to any packet with this destination IP address.
 - `any` applies the rule to traffic to any destination port.
- Rule Option
 - `{msg: "TCP Packet Detected";}` is the message printed with the alert.
- Snort provides many additional actions and protocols, which can be combined to design rules for almost any type of packet.

04. Activity: Intrusion Detection Systems and Snort

- [Activity File: Intrusion Detection Systems and Snort](#)

05. Activity Review: Intrusion Detection Systems and Snort

06. Network Security Monitoring and Security Onion

Network Security Monitoring Overview

In October 2023, hackers released confidential information from 23andMe that contained personally identifiable information (PII) for many of its users, including full names, home addresses, and genealogical information.

- The compromise was achieved by using a common technique referred to as "credential stuffing".
 - This technique involves using a known password that was possibly leaked from another data breach.
- It was later discovered that the compromise included account information beyond just the initial users.
 - 23andMe uses a feature that allows users to share profiles with DNA relatives. This allowed hackers to view some personal information from users that opted in for that feature as well.
- Upon further investigation, it appears that the hackers were able to retrieve data prior to the initial disclosure by about two months.
- If 23andMe had put a network security monitoring program in place, they may have discovered the attack much sooner, perhaps within hours.
- NSM could have allowed 23andMe to stop the attack much sooner, while gaining a good understanding of the TTPs used by the adversary to penetrate the network.
- This could have been accomplished by adding additional layers of defense in the form of an NIDS, NIPS, and HIDS as part of an NSM program.

Security monitoring highlights the failures of existing security controls through the use of data analysis tools. NSM is most useful when the front-end layers of defense are compromised.

It takes time for intruders to achieve their objectives. In many cases, infiltrators spend hours, weeks, months, or even years inside of a network before achieving their final objectives. It's during this critical time that NSM can work to slow and/or eliminate threat-based attacks.

- NSM is threat-centric. Its primary focus is the adversary, not the vulnerability.
- NSM is focused on visibility of an attack, not the response to the attack.
- NSM also reveals statistical data related to specific IOAs and IOCs from attacks.

NSM Strengths

NSM can only protect against the adversarial tactics that it can detect. This detection process takes place when collected data is inspected and irregularities are identified.

NSM allows organizations to:

- Track adversaries through a network and determine their intent.
- Acquire intelligence and situational awareness.
- Be proactive by identifying vulnerabilities.
- Be reactive through incident response and network forensics.
- Provide insights related to advanced persistent threats (APTs).
- Uncover and track malware.

NSM Weaknesses

It's important for security administrators to know the limits of their defenses so they can better prepare new ones. NSM capabilities are extremely limited in the following situations:

- **Encrypted traffic and VPNs:** NSM and IDS do not have the capability to read encrypted traffic. Adversaries will often use this tactic to bypass security defenses.
- **Underpowered hardware:** NSM and IDS require adequate amounts of processing and memory to function well. Larger networks have more traffic, requiring more powerful hardware requirements, and larger expenses.
- **Mobile communication platforms:** Adversaries often use mobile radio communications to obfuscate their attacks because it's difficult for NSM and IDS to monitor radio transmission waves.
- **Legal and privacy issues:** NSM is an invasive process that monitors and records all network data as it passes through. Therefore, there may be legal implications regarding certain types of data collected by an NSM.
- **Limited access to network taps:** The placement of an NSM sensor can be limited at certain areas of the network.

NSM Stages and Processes

NSM operates under two distinct stages, each with two processes.

1. **Detection:** In this stage, an alert is first generated in the Security Onion analyst's console. (Security Onion, which you'll learn about in a moment, is a tool that collects alert data from Snort.)
 - **Collection:** The event is observed and the data is stored in a PCAP file.
 - **Analysis:** The alert data is identified, validated, documented, and categorized according to its threat level.
2. **Response:** In this stage, a security team responds to a security incident with two processes:
 - **Escalation:** All relevant individuals are notified about the incident.
 - **Resolution:** The process of containment, remediation, and any additional necessary response.

NSM Sensor Connectivity

Intrusion detection systems are generally placed at strategic locations in a network where traffic is most vulnerable to attack. These devices are typically placed next to a router or switch that filters traffic.

An **IDS** can be physically connected to a network in two ways:

- **Mirrored port or SPAN:** A SPAN port is a function of an enterprise-level switch that allows you to mirror one or more physical switch ports to another port. A mirror image of all data will flow across both ports equally. This is what allows the IDS to perform packet captures on all inbound and outbound traffic within a network.

- **Network Test Access Point (TAP):** TAPs allow us to access our network and send that data in real time to our monitoring systems. One example of a TAP is known as an aggregated TAP, in which a cable connects the TAP monitor port with the NIC on the sensor. This specific placement allows traffic to be monitored between the router and switch.

Security Onion

Today we'll work with Security Onion, a network security monitoring platform that provides context, intelligence, and situational awareness of a network.

- **Security Onion 2.4** is based on Oracle Linux 9, which is an open source Linux distribution provided for free redistribution by Oracle.
- Security Onion contains a variety of NSM tools used to monitor and protect networks from attacks.
- Security Onion also contains a case management system, also referred to as incident management, to record, identify, and analyze security threats and incidents.

Today we'll use a few NSM tools to help with an incident detection and response routine that will simulate a real-world situation.

There are two ways to work with Security Onion. One is through the shell interface, but most of the actual Security Onion tools and workflow are handled through a web browser.

Certain tools are built directly into the SOC interface. These tools include **Alerts**, **Dashboards**, **Hunt**, **Cases**, and **PCAP**. The other tools will launch into separate browser tabs.

The tools we will be using are:

- **Alerts:** This pulls together alert data generated from Security Onion. It provides important context for alerts, which we can use to complete more detailed analysis of the data.
- **Hunt:** This allows users to create custom queries to help find possible incidents.
- **PCAP:** This provides a way to view details of captured TCP traffic, similar to using tools like Wireshark.
- **Cases:** This allows you to create cases based off of findings to provide a way to track events for further investigation.
- **NetworkMiner:** This performs advanced network traffic analysis. It extracts artifacts from PCAP files and provides an intuitive user interface to analyze them with. It also allows the analyst to analyze, reassemble, and regenerate transmitted files and certificates from PCAP files.

Alert Data

Security Onion uses Suricata rules, similar to those used by Snort, to watch and interpret network traffic and create messages when it sees something it is programmed to report. These alerts are based on patterns of bytes, counts of activity, or even more complicated options that look deeply into packets and streams.

We'll be discussing the workflow using the Alerts in the Security Onion NSM suite. This is the interface that security analysts will use to gain a quick overview of events on their network.

Security Onion Alerts

Security Onion has six key functions that help NSM analysts with their work:

- It performs simple aggregation of alert data records.
- It makes certain types of metadata and related data available.
- It allows queries and review of alert data.
- It allows queries and review of session data.
- It allows easy transitions to drill down into the details of alerts.
- It provides a workflow that allows analysts to generate cases for further escalation and investigation.

The Security Onion Alerts Dashboard allows for the customization of how alerts will be displayed:

The screenshot shows the Security Onion Alerts Dashboard. At the top, the word "Alerts" is on the left, and "Total Found: 167" is on the right. Below "Alerts", there is a search bar with a magnifying glass icon and a dropdown menu set to "Group By Name, Module". To the right of the search bar is a button labeled "Options". Further right is a time filter section with a clock icon, the text "Last 24 hours", and a "REFRESH" button. Below the search bar is a "Fetch Limit" section with a dropdown set to "500" and a "Filter Results" button. Annotations with red arrows point to these sections: "Group Alerts using pre-defined queries" points to the search bar; "Change the length of time to display alerts" points to the time filter; and "Limit how many results are displayed and filter results using keywords" points to the "Fetch Limit" section. Below these controls is a table of alerts.

	Count	rule.name	event.module	event.severity_label
 	45	GPL NETBIOS SMB-DS IPC\$ unicode share access	suricata	low
 	20	GPL NETBIOS SMB IPC\$ unicode share access	suricata	low
 	16	GPL SNMP public access udp	suricata	medium
 	11	ET P2P BitTorrent peer sync	suricata	high
 	9	ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)	suricata	high
 	9	ET MALWARE Zbot POST Request to C2	suricata	high
 	6	ET POLICY PE EXE or DLL Windows file download HTTP	suricata	high
 	6	GPL P2P BitTorrent transfer	suricata	high
 	5	ET HUNTING Mithr Style GET to PHP with invalid large MSIS headers	suricata	medium

- **Alert Results:** Displays detailed alert data, including:
 1. Count displays the number of events matching a specific rule set.
 2. rule.name is the name of the rule that was triggered by the event.
 - The Suricata rule that generated the alert, obtained from the IDS engine
 3. event.module is the module that detected the event (Suricata).
 4. event.severity_label provides a rating for how severe an event should be considered.

Security Onion

Alerts

Options

Total Found: 163

Group By Name, Module

Last 24 hours

Click the clock icon to change to absolute time

Fetch Limit 500

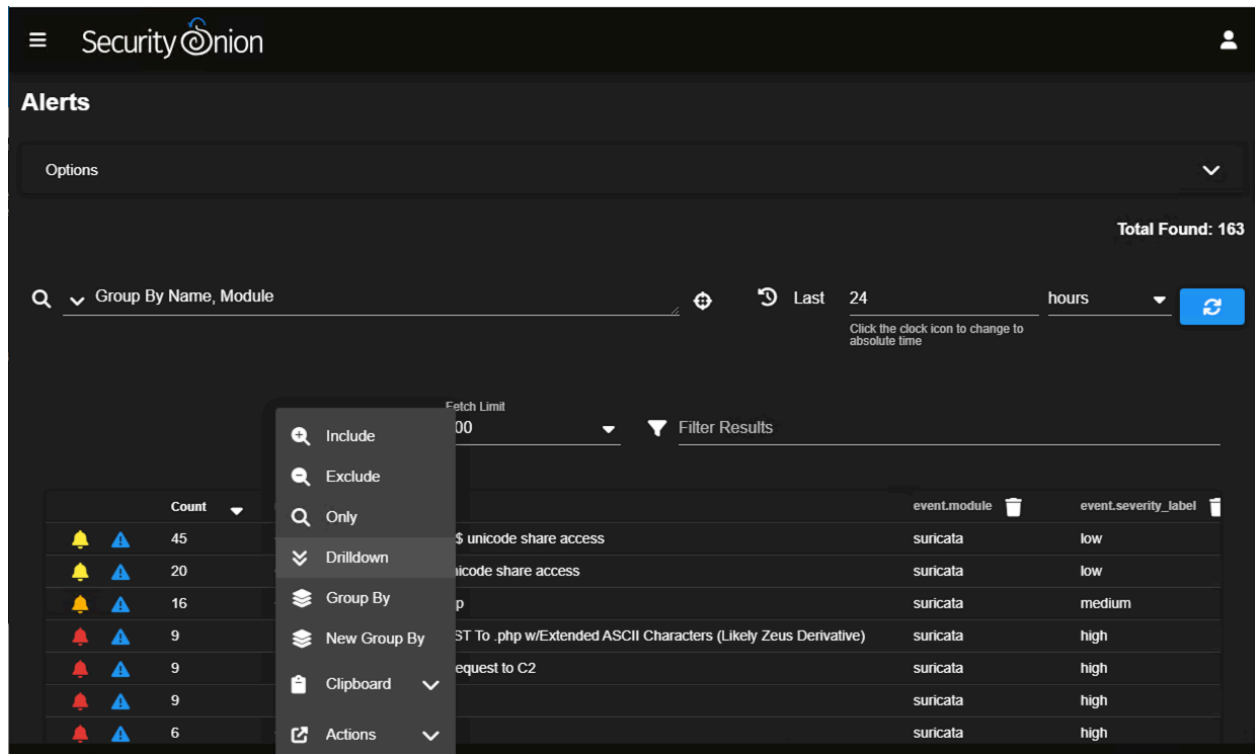
Filter Results

Count	rule.name	event.module	event.severity_label
45	GPL NETBIOS SMB-DS IPC\$ unicode share access	suricata	low
20	GPL NETBIOS SMB IPC\$ unicode share access	suricata	low
16	GPL SNMP public access udp	suricata	medium
9	ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)	suricata	high
9	ET MALWARE Zbot POST Request to C2	suricata	high
9	ET P2P BitTorrent peer sync	suricata	high
6	GPL P2P BitTorrent transfer	suricata	high

- The alert panel has four default fields that we should look at:
 - ST or Status:** Colors indicate severity levels of "real-time" or "RT" events.
 - Red:** Critical, possible data breach in progress. Must be resolved immediately.
 - Orange:** Moderate, high potential for data breach. Requires immediate review.
 - Yellow:** General, low potential for data breach. Requires review.
 - Alert Count:** The number of events created by Security Onion to itemize alert data
 - Rule Name:** IP address of the source identified by the alert
 - Event Severity Level:** The message generated by the Suricata rule option

Security Onion Alert Panel Drilldown

The generated alert can be further examined by clicking it and selecting **Drilldown**. The analyst then must decide if this is benign or malicious. This demonstration will focus on how to obtain data using these tools and the process to make this decision.



Security Onion's Drilldown

The next screenshot is an example of a **Drilldown** on the rule set in Security Onion that activated this alert.

- Suricata Rule:** In the top portion of the window, we see the Suricata NIDS engine that generated the alert data when traffic matched one of its rules.
 - Alert data is an indicator of attack (IOA). An analyst may have to determine if it represents benign or malicious activity.
- Examine Event Fields:** Click on the arrow next to the event to review all of the details regarding the event.

Alerts Options Total Found: 9

Q Custom + ↺ Last 48 hours REFRESH

Click the clock icon to change to absolute time

rule.name:"ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)"

	Timestamp	rule.name	event.severity_label	s
▼	2024-01-05 21:19:47.030 +00:00	ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)	high	1
@timestamp	2024-01-05T21:19:47.030Z			
cloud.account.id	b0e5bc92-9b41-4421-bc7a-515b0d93bdfc			
cloud.instance.id	e02b1130-63e5-41fa-99f4-eeb25cb35e81			
cloud.instance.name	ML-EnvVm-00001			
cloud.machine.type	Standard_D8s_v3			
cloud.provider	azure			
cloud.region	southcentralus			
cloud.service.name	Virtual Machines			
data_stream.dataset	suricata			
data_stream.namespace	so			
data_stream.type	logs			

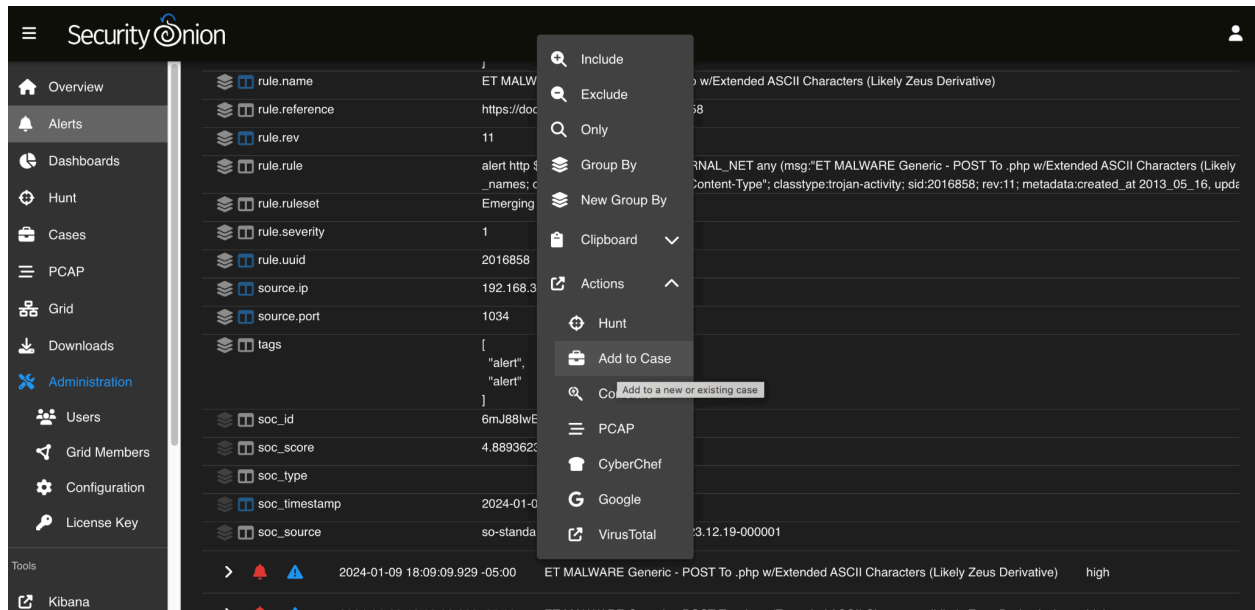
Click here to expand and review event field details

- Scroll down to review the rule that triggered the alert.

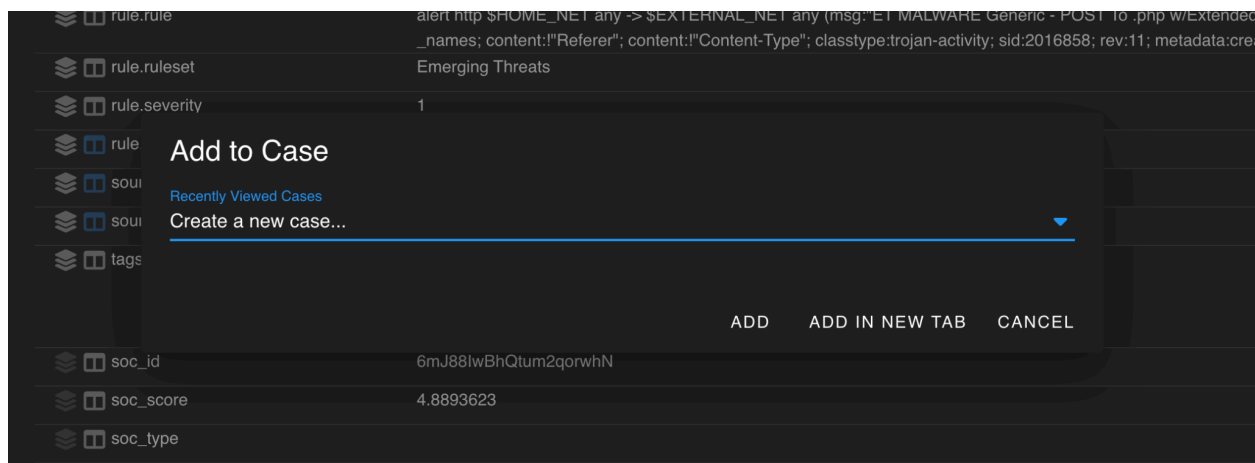
	Content-Length: 169 Connection: Keep-Alive Pragma: no-cache
	xWE.R{.6M.i2y...Yew.S2.9Q#..B.Q.....Q.B.=[_...@!F.@.9].v.....lo.s Q.q.8Vknh.....1M..<9#+.....5xEa.....Xh.....&s.g....f.L...5m.U.....F%. o .."
network.packet_source	wire/pcap
network.transport	TCP
observer.name	securityonion
rule.action	allowed
rule.category	A Network Trojan was detected
rule.gid	1
rule.metadata.created_at	["2013_05_16"]
rule.metadata.updated_at	["2020_08_17"]
rule.name	ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)
rule.reference	https://doc.emergingthreats.net/2016858
rule.rev	11
rule.rule	alert http \$HOME_NET any -> \$EXTERNAL_NET any (msg:"ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)"; pcre:"^.{0,3}[\x80-\xff]{1,3}[\x00-\x7f]{1,3}[\x80-\xff]{1,3}[\x80-\xff]{1,3}"; http.header_names; content:"Referer"; content!"Content-Type"; clas
rule.ruleset	Emerging Threats
rule.severity	1

Rule that triggered the alert

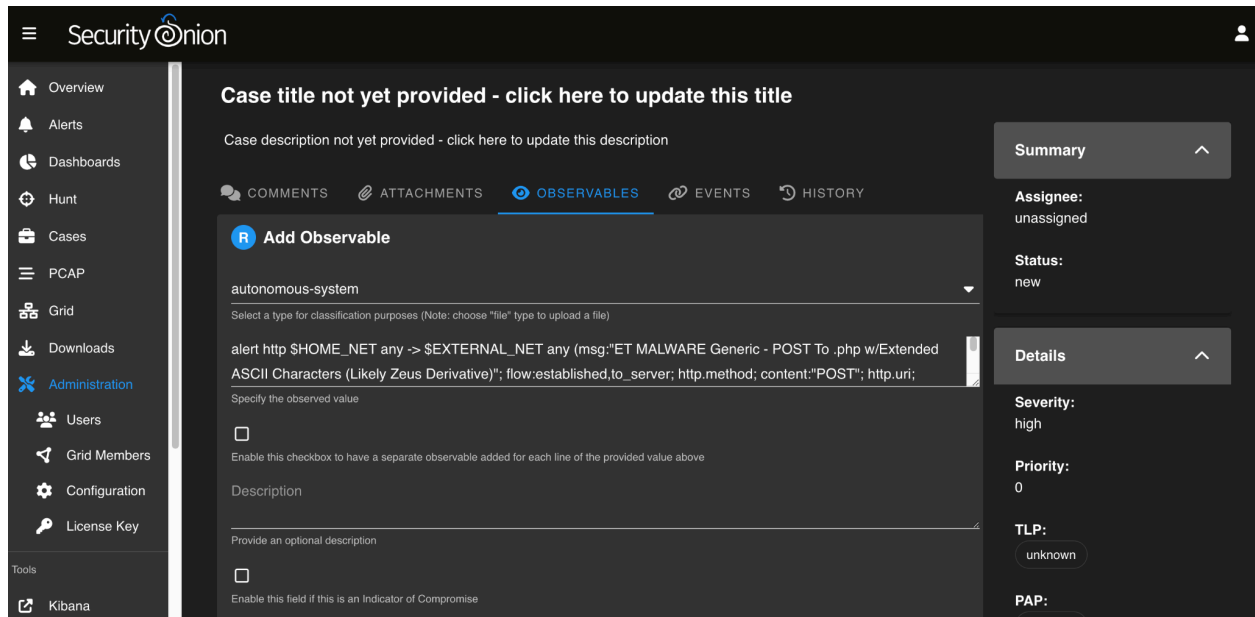
- Rule names begin with text like "ET" (for Emerging Threats, an IDS rule source).
- **Add Event to a Case:** An incident like this probably requires further investigation.
 - Add this alert to a Case by clicking on it and select **Add to Case**.



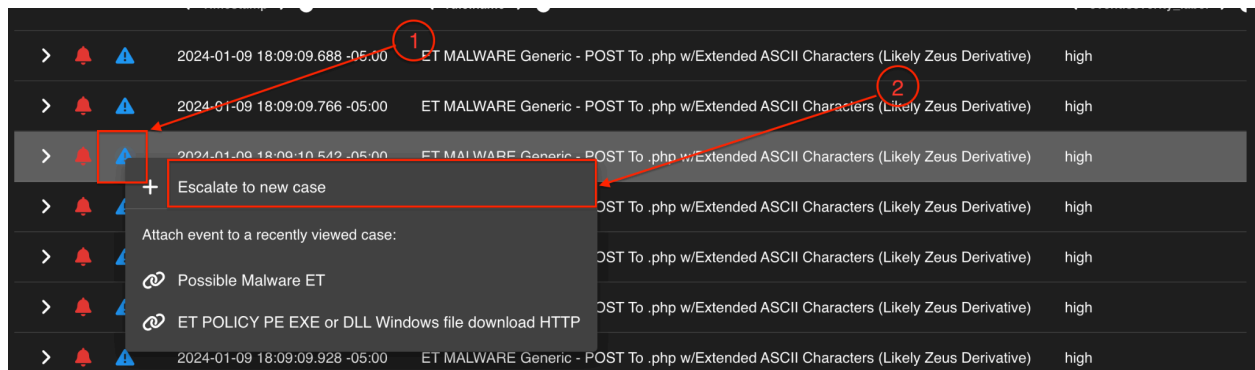
- A prompt will ask whether to create a new case or add it to an existing case.



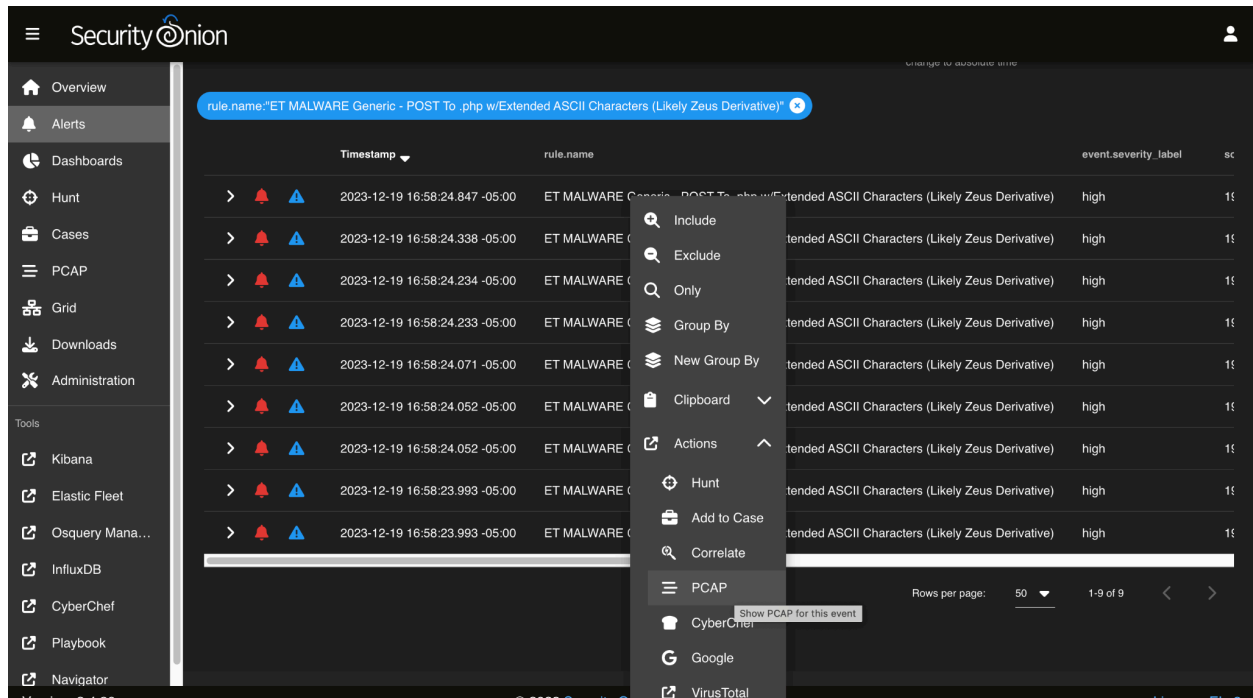
- Once the case is created you will be prompted to add details like case title, comments, attachments, events, etc.



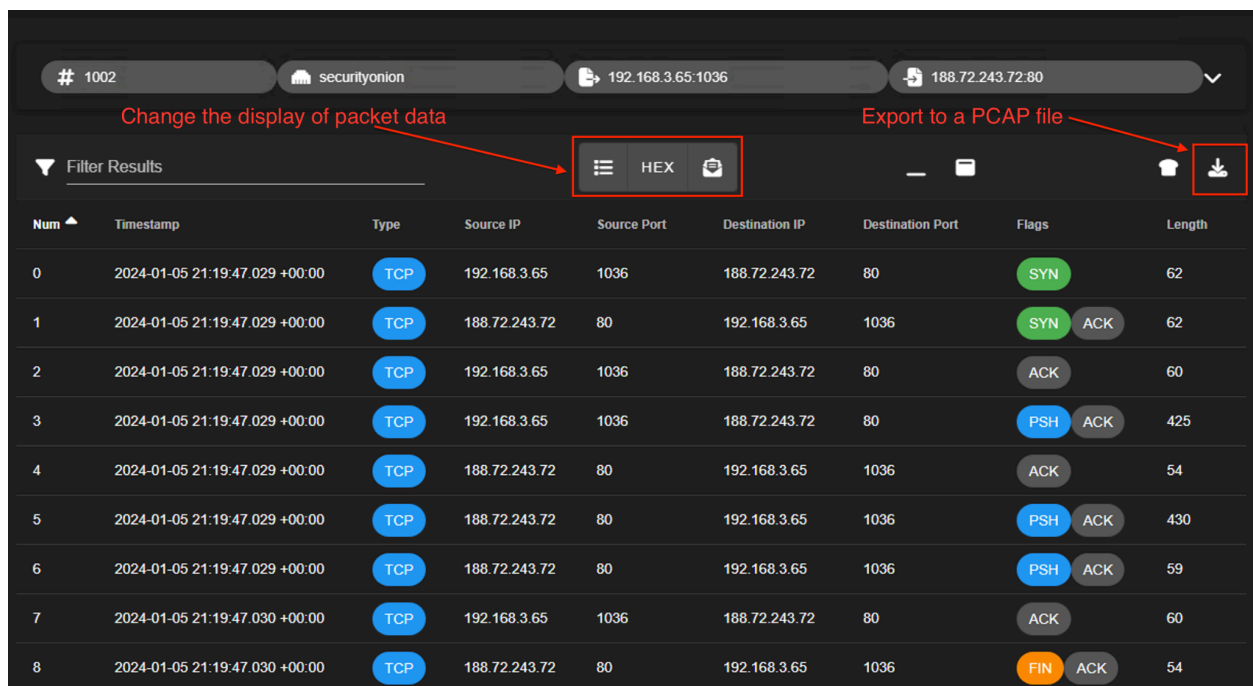
- Alternatively, you can quickly pivot by clicking on the blue triangle with an exclamation point (1) and click `Escalate` to new case.
 - This will populate a lot of the data for you automatically based on the event.



- **PCAP Data:** The packets can be further examined by going into PCAP view.
 - Click on `Alerts` on the left and select one of the alerts listed as malware.
 - This example uses the alert `ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)`
 - When the results are filtered, click on one of the alerts and select `PCAP` from the dropdown.



- The PCAP option shows a more detailed view of the data capture. It includes more packet information and data streams presented in hex and text form. From here, the actual packet capture can also be exported to allow it to be opened in other tools, like Wireshark, for further analysis.



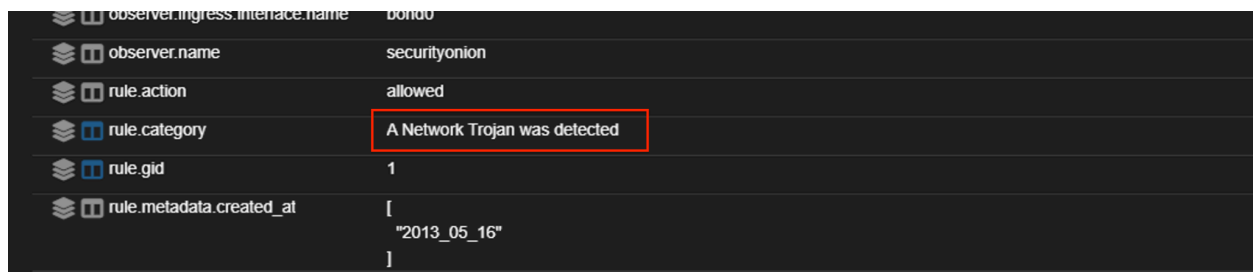
Analyzing PCAP Data

An analyst can use data found within packet captures to reveal identifying information about an attacker. This includes their domain name registries, and IP addresses.

- Other information may include the country of origin, and, ideally, the names, email addresses, or phone number of the DNS registrants.

Analysts can utilize the data to formulate attacker profiles or determine characteristics of an attack.

- Click on `Alerts` in the left column.
- Find the `ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)` alert.
- Click on the alert and select `Drilldown` from the pop-up menu.
- Expanding the results from the `Drilldown` will provide additional details about the alert.
 - For example, the details below indicate the category of the alert triggered. In this case, the alert indicates that a trojan was detected.

A screenshot of a network security interface showing a drilldown of an alert. The interface has a dark theme. A red rectangle highlights the 'rule.category' field, which contains the text 'A Network Trojan was detected'. Other fields visible include 'observer.ingress.interface.name' (bond0), 'observer.name' (securityonion), 'rule.action' (allowed), 'rule.gid' (1), and 'rule.metadata.created_at' (2013_05_16).

observer.ingress.interface.name	bond0
observer.name	securityonion
rule.action	allowed
rule.category	A Network Trojan was detected
rule.gid	1
rule.metadata.created_at	["2013_05_16"]

07. Activity: Security Onion and NSM Overview

- [Activity File: Security Onion and NSM Overview](#)

08. Activity Review: Security Onion and NSM Overview

09. Break

10. Alert - HTTP File Extraction

An alert will sometimes require an analyst to do some data mining. To do this, a security analyst must have a thorough understanding of how NSM tools are integrated. These skills help speed up incident and response efforts.

In the following walkthrough, we will explore the Security Onion interface, using Security Onion as the starting point for learning other NSM tools for security investigations.

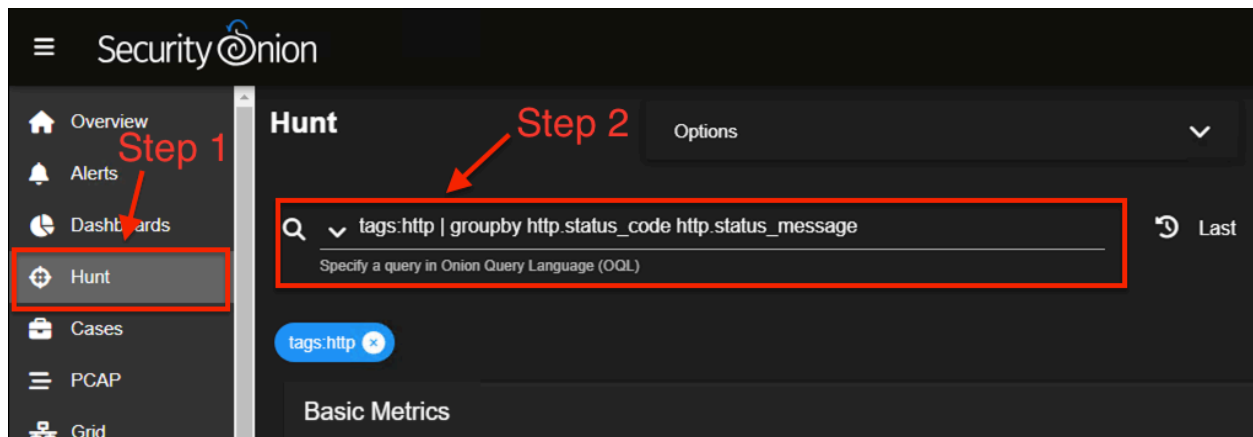
Security Onion Demo

The first thing we will do is search using a filter for the IP address from the indicator of attack (IOA).

Launch an instance of Security Onion:

- Step 1: Click the Hunt icon on the left.
- Step 2: Select HTTP from the dropdown to group the results by the HTTP command.

Now, we will only see information related to our filtered alert data.



Next, scroll down to the bottom to review the results:

- From this example, you can see there is a lot of HTTP traffic. Narrow down the results by filtering by local IP 192.168.3.35.

Events						
		Fetch Limit	100	▼	192.168.3.35	✖
Timestamp	source.ip	source.port	destination.ip	destination.port	http.m	
> ▲ 2024-04-04 06:24:23.920 +00:00	192.168.3.35	1033	195.2.253.92	80	GET	
> ▲ 2024-04-04 06:24:24.652 +00:00	192.168.3.35	1046	96.0.203.90	80	POST	
> ▲ 2024-04-04 06:24:24.654 +00:00	192.168.3.35	1047	96.0.203.122	80	POST	

Now, we can see from the results that this user downloaded a file from a website. Select the packet using the GET http.method, click on Actions and then on PCAP.

Timestamp	source.ip	source.port	destination.ip	destination.port	http.m	
> ▲ 2024-04-04 06:24:23.920 +00:00	192.168.3.35	1033	195.2.253.92	80	GET	
> ▲ 2024-04-04 06:24:24.652 +00:00	192.168.3.35	1046	96.0.203.90	80	POST	
> ▲ 2024-04-04 06:24:24.654 +00:00	192.168.3.35	1047	96.0.203.122	80	POST	

The backend data fetch took 0.063 seconds. The total time taken was 0.063 seconds.

Rows per page: 10 1-3 of 3

Include
Exclude
Only
Group By
New Group By
Clipboard
Actions
Hunt
Add to Case
Correlate
PCAP
CyberChef

Once the PCAP page opens, click to download the PCAP file.

Filter Results								
Num	Timestamp	Type	Source IP	Source Port	Destination IP	Destination Port	Flags	Length
0	2024-04-04 06:21:54.870 +00:00	TCP	192.168.3.35	1033	195.2.253.92	80	SYN	62

Click to download PCAP

Download icon

- Now take this PCAP file and open it using a new forensic tool.
- This tool can extract any files that were installed on the user's machine, and provide us with an attacker profile.

NetworkMiner

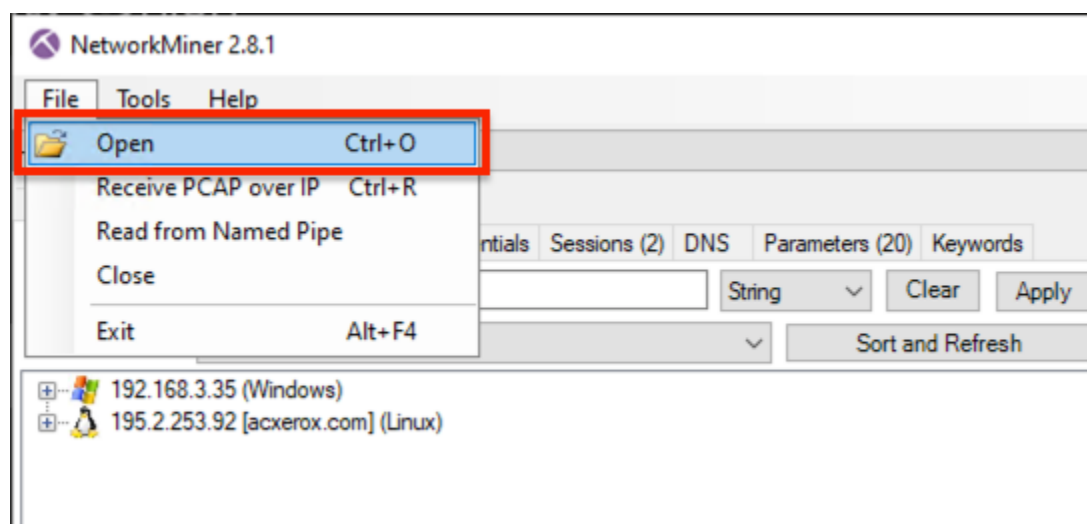
NetworkMiner is an NSM tool that's included as part of the Security Onion NSM suite.

- NetworkMiner performs advanced network traffic analysis (NTA) of extracted artifacts, and presents them through an intuitive user interface.

NetworkMiner by following the steps below.

Note: Details may vary slightly from screenshot but the concepts still apply.

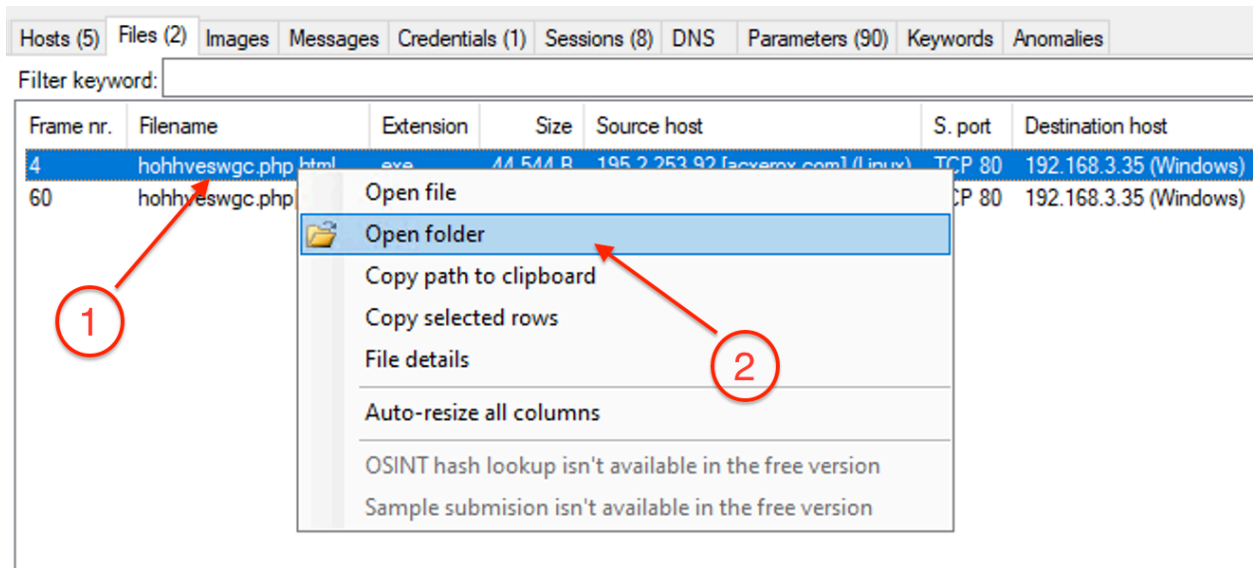
- Click on **NetworkMiner** and click **File**, then **Open** and select the PCAP file from your downloads folder.



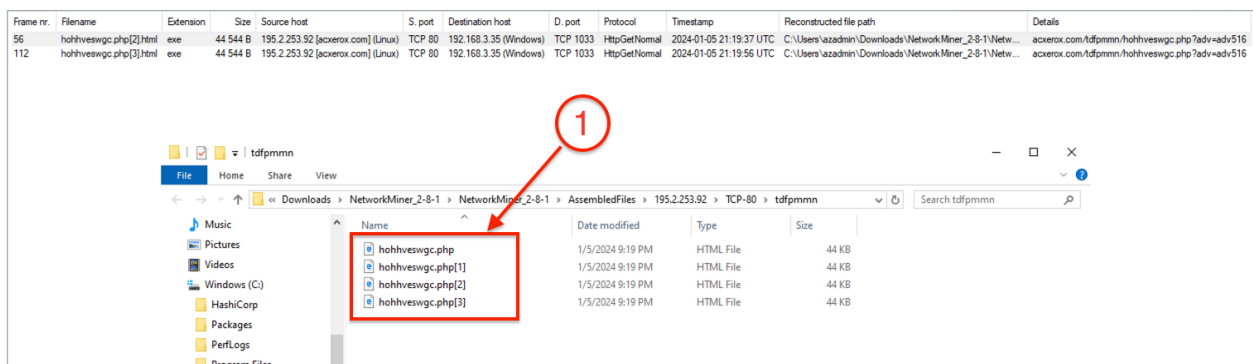
- On the NetworkMiner's interface. Pay attention to the tabs at the top. We'll focus on the **Files** tab next.
- Select the **Files (2)** tab as seen in the screenshot. This tells us that NetworkMiner was able to extract and reconstruct the two files from Security Onion's PCAP captures.
- Review the source port and protocol used.
- Review the protocols used during transmission.

Hosts (4) Files (2) Images Messages Credentials (1) Sessions (6) DNS Parameters (72) Keywords Anomalies										
Filter keyword:										
					☐ Case sensitive	ExactPhrase	Any column	Clear	Apply	
Frame nr.	Filename	Extension	Size	Source host	S. port	Destination host	D. port	Protocol	Timestamp	Reconstructed file path
4	hohhveswgc.php.html	exe	44 544 B	195.2.253.92 [acxerox.com] (Linux)	TCP 80	192.168.3.35 (Windows)	TCP 1033	HttpGetNormal	2024-01-05 21:19:37 UTC	C:\Users\azadmin\Downloads\NetworkM
60	hohhveswgc.php[1].html	exe	44 544 B	195.2.253.92 [acxerox.com] (Linux)	TCP 80	192.168.3.35 (Windows)	TCP 1033	HttpGetNormal	2024-01-05 21:19:56 UTC	C:\Users\azadmin\Downloads\NetworkM

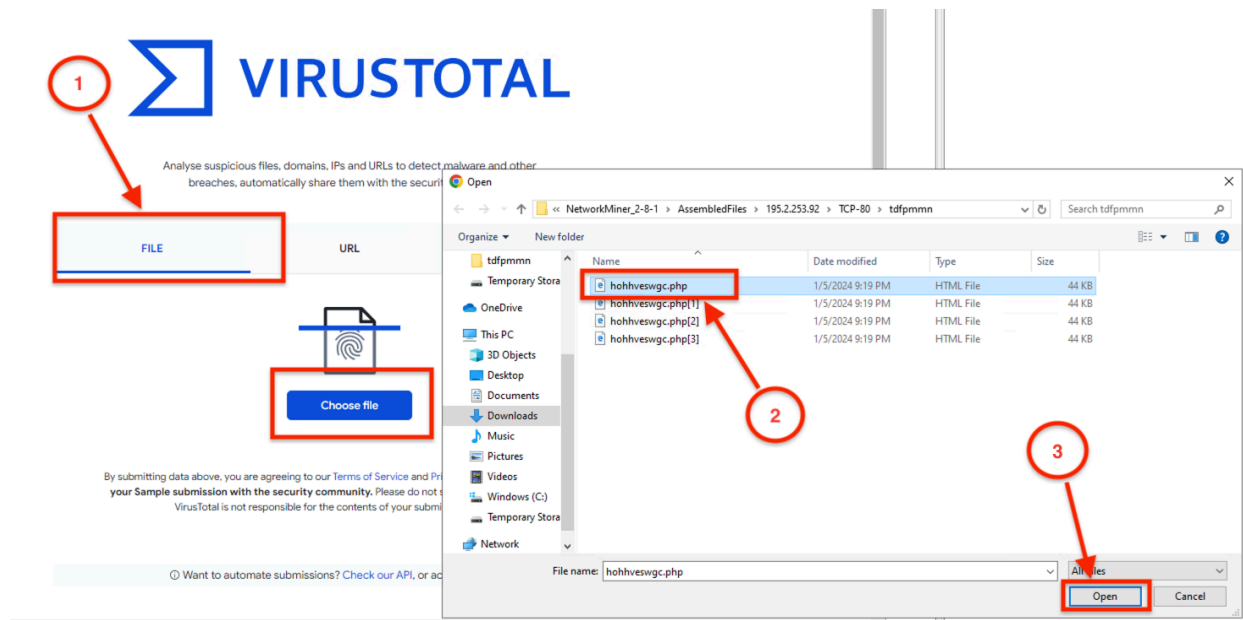
- Right-click on one of the files.
- Click on **Open folder**.



- This will open the folder on the local hard disk where NetworkMiner stores the recompiled files.



- Next, open the Chrome Web Browser, navigate to www.virustotal.com, and select **File**.
- These are parts of the malware. We can click and select on any one of the files and get results. Select the `hohhveswgc.php` file for inspection.



The VirusTotal search tool will attempt to match these files to any known malware signatures.

- VirusTotal returned the number of matches it discovered for well-known virus engines against this particular file.
- VirusTotal hashes the files, which establishes a malware signature used to look for a match and determine the common name for the malware.
- Finally, VirusTotal lists all of the common names for this specific malware.

Security professionals, especially security researchers, use this website frequently when performing malware analysis and establishing the TTPs used by adversaries to infiltrate networks. This information contributes to what is commonly referred to in the industry as an "attacker profile." These help us know our enemies and better defend against future attacks.

4ff5d3185b8cadea1def90ac62c39fe849abfa36abb6d103c65e0aa36788c2ae

61

172

61 security vendors and 1 sandbox flagged this file as malicious

Reanalyze

Similar

More

4ff5d3185b8cadea1def90ac62c39fe849abfa36abb6d103c65e0aa36788c2ae

Size

43.50 KB

Last Analysis Date

2 months ago

Start.exe

Size

43.50 KB

Last Analysis Date

2 months ago

peexe

spreader

Community Score

DETECTION

DETAILS

RELATIONS

BEHAVIOR

COMMUNITY 3

Join the VT Community and enjoy additional community insights and crowdsourced detections, plus an API key to [automate checks](#).

Popular threat label

trojan.krypt/zbot

Threat categories

trojan ransomware spyware

Family labels

krypt zbot krap

Security vendors' analysis

Do you want to automate checks?

AhnLab-V3	Win-Trojan/Zbot10.Gen	Alibaba	VirTool:Win32/Obfuscator.51a0c37b
ALYac	Gen:Heur.Krypt.22	Antiy-AVL	Trojan[Spy]/Win32.Zbot
Arcabit	Trojan.Krypt.22	Avast	Win32:Evo-gen [Trj]
AVG	Win32:Evo-gen [Trj]	Avira (no cloud)	TR/Crypt.XPACK.Gen
BitDefender	Gen:Heur.Krypt.22	BitDefenderTheta	AI:Packer.684FB2AD1F
Bkav Pro	W32.ReadersTuti.Heur	ClamAV	Win.Packed.Zbot-9851073-0

Summary

The strength of NSM depends on knowing the limits of what you can see and detect, developing an understanding of adversarial tactics, and applying that knowledge to mitigate future attacks. This process happens when collected data is inspected and irregularities are identified.

NSM allows organizations to:

- Track adversaries through a network and determine their intent.
- Acquire intelligence and situational awareness.
- Be proactive by identifying vulnerabilities.
- Be reactive through incident response and network forensics.
- Provide insights related to APTs.
- Uncover and track malware.

11. Activity: Alert - FTP File Extraction

- [Activity File: Alert - FTP File Extraction](#)

12. Activity Review: Alert - FTP File Extraction